

Circumvention of Network Filtering

Network Filtering / Egress Control – PoC – 16/9/2026

Table of Contents

2.1 – The setup	5
<i>Details</i>	<i>5</i>
Client Device:.....	5
Client Software:	5
Server (VPS):	5
Server Software:	5
Network:.....	5
<i>Why this matters?.....</i>	<i>5</i>
2.2 – Components	5
3.1 – SNI spoofing.....	6
<i>What is it?.....</i>	<i>6</i>
<i>What was done?</i>	<i>6</i>
<i>Result</i>	<i>6</i>
3.2 – Packet fragmentation (tlshello).....	6
<i>What is it?.....</i>	<i>6</i>
<i>What was done?</i>	<i>6</i>
<i>Result</i>	<i>6</i>
3.3 – Xray TUN	7
<i>What is it?.....</i>	<i>7</i>
<i>What was done?</i>	<i>7</i>
<i>Result</i>	<i>7</i>
3.4 – Mux (Multiplexing)	7
<i>What is it?.....</i>	<i>7</i>
<i>Result</i>	<i>7</i>
3.5 – DoU with query strategy (UseIP)	7
<i>What is it?.....</i>	<i>7</i>
<i>What was done?</i>	<i>7</i>
<i>Result</i>	<i>7</i>
5.1 – Web filtering.....	9

5.2 – Safeguarding.....	9
5.3 – Malware/phishing	9
5.4 – Application restrictions	9
5.5 – Monitoring/attribution	9
5.6 – Data transfer.....	9
5.61 – Caveat:	9
6.1 – JANET / eduroam	10
6.2 – Fortinet/FortiGate.....	10
Question.....	10
6.3 Lightspeed Systems.....	11
6.31 – Critical limitation	11
7.1 Egress control.....	12
7.2 Endpoint application control.....	12
7.21 – BYOD limitation	12
7.3 VPN and proxy detection	12
7.4 Encrypted DNS controls.....	12
7.5 Monitoring and alerting.....	13
7.6 BYOD and NAC controls	13
For BYOD devices:	13
10.1 – Mitigation.....	18
12.1 – Appendix A: Glossary	20
12.2 – Appendix B: Attack chain.....	21
12.3 – Appendix C: Security control mapping	22

1 – Introduction

This report documents a proof-of-concept (PoC) finding where a BYOD (Bring Your Own Device) laptop connected to the college's eduroam network was able to bypass network filtering controls using an encrypted tunnel to an external server.

The goal of this test was to see whether the college's existing network filtering (DNS blocking, web filtering, etc.) could be circumvented from a device the college does not manage. The client device in this case was not a college-managed laptop – it was a personal BYOD device running V2Box, a client-side application for Xray-core, to establish the tunnel.

@tay737

2 – What was used and why?

2.1 – The setup

Details

Client Device: BYOD laptop (not managed)

Client Software: V2Box (Xray-core client)

Server (VPS): Ubuntu 26.04.1 LTS (Resolute Raccoon)

Server Software: Xray-core with VLESS + Reality

Network: eduroam (SSID)

The VPS was a Linux server hosted outside the college network. It ran Ubuntu 26.04.1 LTS, which is the first maintenance release of the 26.04 LTS series and includes security updates up to August 2026. The server ran Xray-core configured with VLESS and Reality.

Why this matters?

The college network could potentially see the connection to the VPS, but it could **not** see what happened after the traffic reached the VPS. The VPS acted as an intermediary, making onward connections to whatever websites or services the client requested.

2.2 – Components

Xray-core – This is the software that handles the **tunnelling**. It is open-source and supports many different proxy protocols and transport methods.

VLESS – This is the protocol used to carry the client's traffic through the tunnel. It is lightweight and does not use its own encryption layer; instead, it relies on the transport (like **TLS**) to provide security.

Reality – Functions by "borrowing" the TLS fingerprint of a real website (like www.apple.com) so that the encrypted connection looks exactly like a normal HTTPS connection to that site.

V2Box – This is the client application on the BYOD device. It creates a **TUN interface** and passes traffic to Xray-core.

3 – Configuration features used in the PoC

The PoC used several specific configuration features. These are explained below because they are directly relevant to why the college firewall only saw an encrypted connection to the VPS.

3.1 – SNI spoofing

What is it?

When a browser or app makes an HTTPS connection, it sends a "ClientHello" message that includes the Server Name Indication (SNI) – basically, the hostname it wants to reach. Filtering systems often look at the SNI to decide whether to allow or block the connection.

What was done?

Using Xray, the SNI was set to a legitimate, allowed domain (like a popular CDN or cloud provider) instead of the VPS's actual hostname.

Result

The firewall saw an SNI for an allowed site and let the connection through. It did not know the real destination was the VPS.

3.2 – Packet fragmentation (tlshello)

What is it?

Normally, the TLS ClientHello is sent in one TCP packet. Some firewalls and DPI (Deep Packet Inspection) systems expect this and inspect the packet to extract the SNI or match a fingerprint.

What was done?

We used Xray's tlshello fragmentation mode, which splits the ClientHello across multiple TCP segments.

Result

Firewalls that do not reassemble fragmented TCP streams correctly may fail to extract the SNI or match known TLS fingerprints. This makes SNI-based blocking less reliable.

3.3 – Xray TUN

What is it?

TUN (Tunnel) mode creates a virtual network interface on the device. All IP traffic – not just traffic from specific apps – is routed through this interface and into the tunnel.

What was done?

V2Box created a TUN interface using the device's VPN service API.

Result

The tunnel captured device-wide traffic, including DNS. This meant that even applications that do not support proxy settings could be tunnelled.

3.4 – Mux (Multiplexing)

What is it?

Mux combines multiple logical streams over a single encrypted connection. Instead of the network seeing many separate connections to many destinations, it sees one long-lived connection to the VPS.

Result

This reduces connection-level indicators. A network monitor might see one persistent TLS connection to the VPS, but it cannot easily tell that many different websites are being accessed inside it.

3.5 – DoU with query strategy (UseIP)

What is it?

DoU (DNS over UDP) is a way of doing DNS lookups. The UseIP query strategy tells the client/proxy to resolve domain names to IP addresses.

What was done?

DNS resolution was handled through the tunnel/configured resolver path rather than through the college's DNS servers.

Result

The college's DNS filtering had reduced visibility of the final destinations. DNS queries for blocked domains were not seen by the college's DNS infrastructure.

4 – Sequence of events

Client connects to eduroam – BYOD device authenticates to the college network normally (standard student privileges/access – low)

Normal filtering applies – The college's DNS and web filtering are active.

V2Box is installed on the BYOD device – Because the device is not managed by the college, there is no endpoint control to prevent this.

V2Box creates a TUN interface – Captures device-wide traffic > routes it into the Xray-core tunnel.

Encrypted session to the VPS is established – Via VLESS + Reality, client connects to the external VPS on port 443 (HTTPS).

SNI spoofing and tlshello fragmentation are applied – TLS ClientHello appears to target a legitimate site, and it is fragmented across multiple packets.

Mux multiplexes streams – Multiple connections are combined into one session (encrypted).

DoU with UseIP handles DNS – DNS resolution happens inside the tunnel, not through college DNS.

The network sees: Client ↔ External VPS (encrypted, port 443).

The network does NOT see: Final destinations (websites, services) accessed through the tunnel.

The VPS makes onward connections – VPS resolves the requested domains and connects to the actual Internet destinations.

Responses return through the tunnel – Client receives content, college network unaware of what was accessed.

5 – Security impact

5.1 – Web filtering

Users can access websites that are normally blocked by domain or category. The college's web filter sees only the connection to the VPS, not the destination.

5.2 – Safeguarding

Content filtering intended to restrict access to inappropriate or unsafe material becomes less effective. This is particularly relevant in an educational setting.

5.3 – Malware/phishing

Security controls that depend on seeing the destination domain or URL have reduced visibility when traffic is encapsulated inside an encrypted tunnel.

5.4 – Application restrictions

Applications and protocols that are normally identified and blocked by network controls become much harder to classify.

5.5 – Monitoring/attribution

Network monitoring records a connection to the tunnel endpoint (the VPS) rather than the ultimate destination. This makes it harder to investigate incidents or enforce policy.

5.6 – Data transfer

An encrypted intermediary could potentially be used to transfer data in ways that are not visible to conventional destination-based filtering.

5.61 – Caveat: The actual impact depends on the college's endpoint controls, network architecture, filtering configuration, BYOD policy, and monitoring capabilities. This PoC demonstrates a potential visibility gap, not a guaranteed bypass of all controls.

6 – Cross-ref w/ implemented systems

6.1 – JANET / eduroam

According to the eduroam technical specification, it allows organisations to implement default-deny firewalling for outbound traffic from visitor facilities. The specification requires only a minimum set of protocols to be allowed (web browsing, file access, email, and certain VPN protocols). This means the college is permitted to restrict outbound traffic more tightly. The fact that the tunnel worked suggests that either:

Egress controls are not configured to block this type of traffic, or

The tunnel traffic is not being reliably identified by the existing controls.

JANET eduroam security measures also state that visitor networks should be separated from the campus network and treated as untrusted. In this PoC, the BYOD device was on eduroam, which is the appropriate segmentation. The issue is that egress controls from that segment did not **prevent** the tunnel.

6.2 – Fortinet/FortiGate

FortiGate firewalls support SSL/TLS inspection to decrypt and inspect encrypted traffic. They can operate in two modes: certificate inspection (looks at certificate metadata without decrypting) and deep inspection (decrypts and inspects content).

In this PoC, the use of SNI spoofing, tlshello fragmentation, and Mux would **reduce** the effectiveness of certificate inspection. Deep inspection may also be challenged if the firewall cannot reassemble fragmented TLS ClientHello packets. Fortinet documentation notes that MTU/fragmentation issues can cause connection failures or **inspection gaps**.

Question: Is SSL deep inspection enabled on the egress policy for eduroam traffic? If so, can it handle fragmented ClientHello and TLS 1.3?

6.3 Lightspeed Systems

Lightspeed Filter includes **Real-Time Bypass Detection** > analyses browser behaviour, DOM structure, and known proxy library fingerprints (e.g. Ultraviolet and Rammerhead) to detect bypass tools. This detection works on managed devices (ChromeOS, Windows, macOS) where the Lightspeed helper extension is installed.

6.31 – Critical limitation: In this PoC, the client device was a BYOD device **not** managed by the college. Lightspeed's endpoint agent was **not** installed. Therefore, Lightspeed's bypass detection had no visibility into the V2Box application or TUN interface on the client device.

Lightspeed's filtering: effective at detecting browser-based proxy frameworks and bypass tools on managed devices. It is **not** designed to detect or block a device-level encrypted tunnel (like V2Box) on an unmanaged device.

This explains why the observed Lightspeed blocking behaviour on college-administered devices did not apply to the VLESS/Reality tunnel.

@tay737

7 – Recommendations

7.1 Egress control

Review outbound Internet access from the eduroam/student network. Where operationally practical, restrict outbound traffic to required protocols and destinations. Unrestricted outbound connectivity to arbitrary VPS/cloud infrastructure is the root enabler of this finding.

7.2 Endpoint application control

Prevent installation/execution of VPN clients, proxy clients, and tunnelling software on college-managed devices. Application allowlisting should be considered for high-security environments.

7.21 – BYOD limitation: This will not work on unmanaged BYOD devices because the college does not control the device. For BYOD, the college must rely on network-based controls and NAC.

7.3 VPN and proxy detection

Enable the filtering platform's available VPN/proxy/anonymisation detection capabilities. Test detection against multiple tunnelling technologies, not just one specific application.

7.4 Encrypted DNS controls

Verify that users cannot bypass organisational DNS policy through:

DNS-over-HTTPS (DoH)

DNS-over-TLS (DoT)

DNS-over-UDP (DoU) to external resolvers

Manually configured DNS

Application-specific DNS resolvers

7.5 Monitoring and alerting

Establish alerts for:

Unusual external tunnel endpoints (especially VPS/cloud infrastructure)

Persistent, encrypted sessions from client networks

Abnormal outbound traffic volumes

SNI mismatch (SNI does not match destination IP reputation or certificate)

Fragmented TLS ClientHello packets

Multiplexed traffic patterns (one connection, many destinations)

7.6 BYOD and NAC controls

For BYOD devices:

NAC to assess device compliance.

Restrict access to sensitive resources from unmanaged devices.

Apply separate network segments/policies for BYOD traffic.

Consider blocking known VPN/tunnel application categories at the network edge where feasible.

Accept that determined users with unmanaged devices may still find ways to tunnel unless egress is tightly controlled.

8 – Tests

*Recommendations that will help to reproduce the finding, and how to **mitigate** it.*

ID	Target	Methods	Expected outcome
01	Baseline filtering	Browse directly to known blocked domain – gaming, gambling, adult)	Connection dropped or redirected to firewall block page.
02	Tunnel bypass	Establish V2BOX/Xray tunnel and attempt to load the same blocked domain.	Firewall drops initial tunnel handshake to VPS, preventing a proxy connection from forming whatsoever.
03	DoT	Run: ns lookup or dig query e.g. dig @1.1.1.1 google.com +tls	Firewall drops outbound packet on 853, leading to connection timeout.
04	DoU	Force client device to use external DNS provider on 53 e.g. dig @8.8.8.8 google.com	Firewall blocks request or forces DNS sinkhole redirect back to internal DNS servers
05	Standard VPN protocols	Establish WireGuard/OpenVPN handshake to commercial (external) server.	FortiGate application control identifies handshake and drops traffic.
06	Reality/TLS spoofing	Start Xray connection using borrowed SNI over port 443	FortiGate deep inspection > JA3/JA4 mismatch > drops session
07	SNI spoofing	curl --connect-to or modified OpenSSL to send request where SNI header + destination IP mismatch	Firewall URL or domain filter > flags mismatch > drops connection.
08	clientHello fragmentation (TLS)	Deploy Xray client with fragmentation enabled split handshakes across multiple TCP segments	FortiGate IPS engine > reassembles segments and extracts hidden SNI or drops packet as invalid SSL (unable to be parsed)
09	Persistence in encrypted sessions	Open a continuous high-volume muxed stream through the tunnel for more than 60 minutes.	SIEM flags long-lived session to unknown IP/host.
10	Egress access	Attempt direct outbound connection to a raw IP address belonging to known “cheap” VPS providers (OVHcloud, Hetzner etc.)	Egress firewall policy blocks direct IP-only routing on 443 > prior valid DNS resolution required.

9 – Demonstration

Due to the network configuration, most speed-testing sites (e.g. Ookla) are unable to function. This is likely a firewall issue, which has been observed on college-administered devices. Therefore, this demonstration has been conducted using the speed-testing site. Identifying information has been redacted and the screenshots have been organised chronologically.

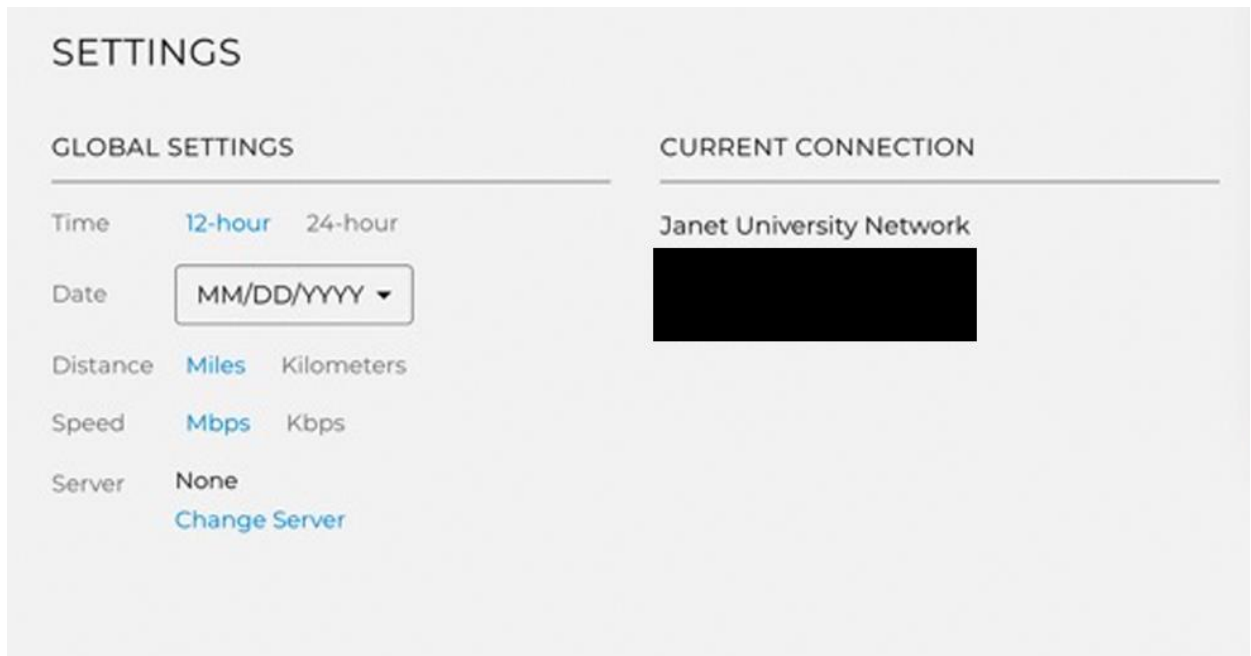


Figure 1: Settings page before establishing tunnel.

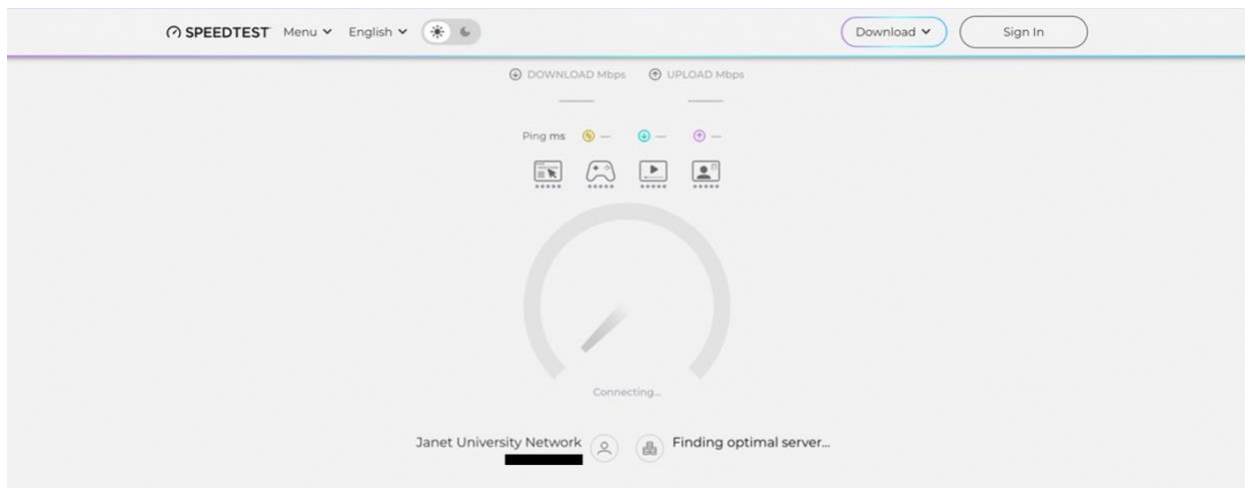


Figure 2: Attempt to run speed-test before establishing tunnel.

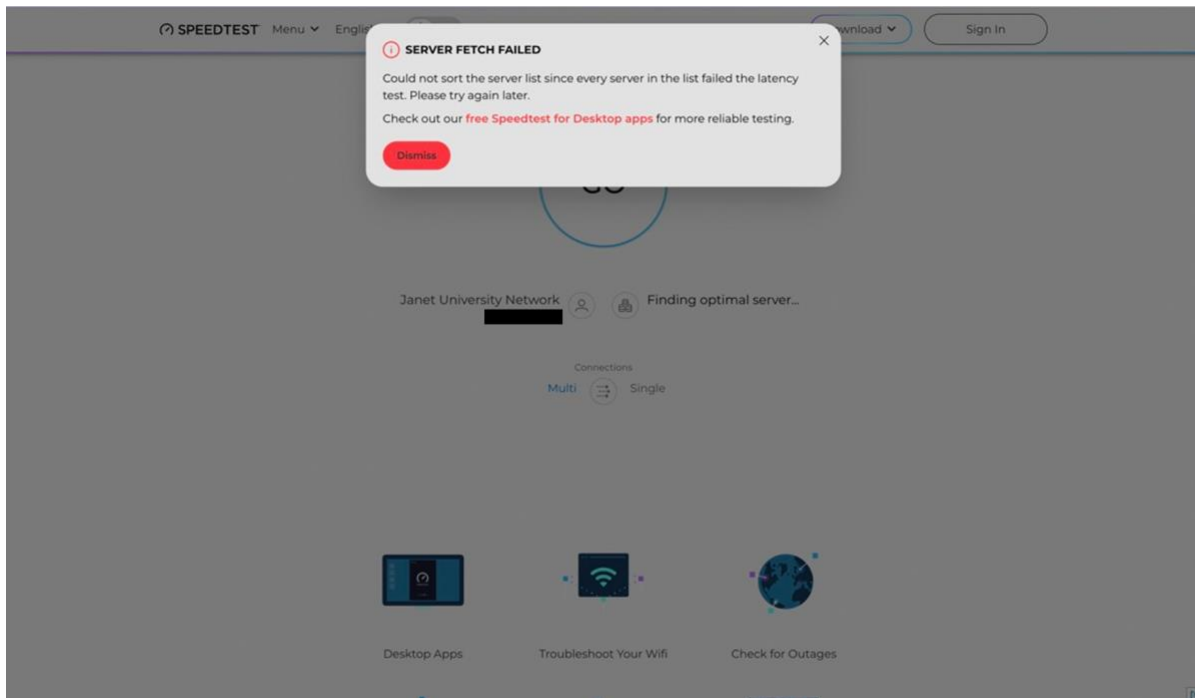


Fig 3: Unable to run speed-test before establishing tunnel.



Fig. 4: Pinging external VPS server before establishing tunnel – all requests time out.

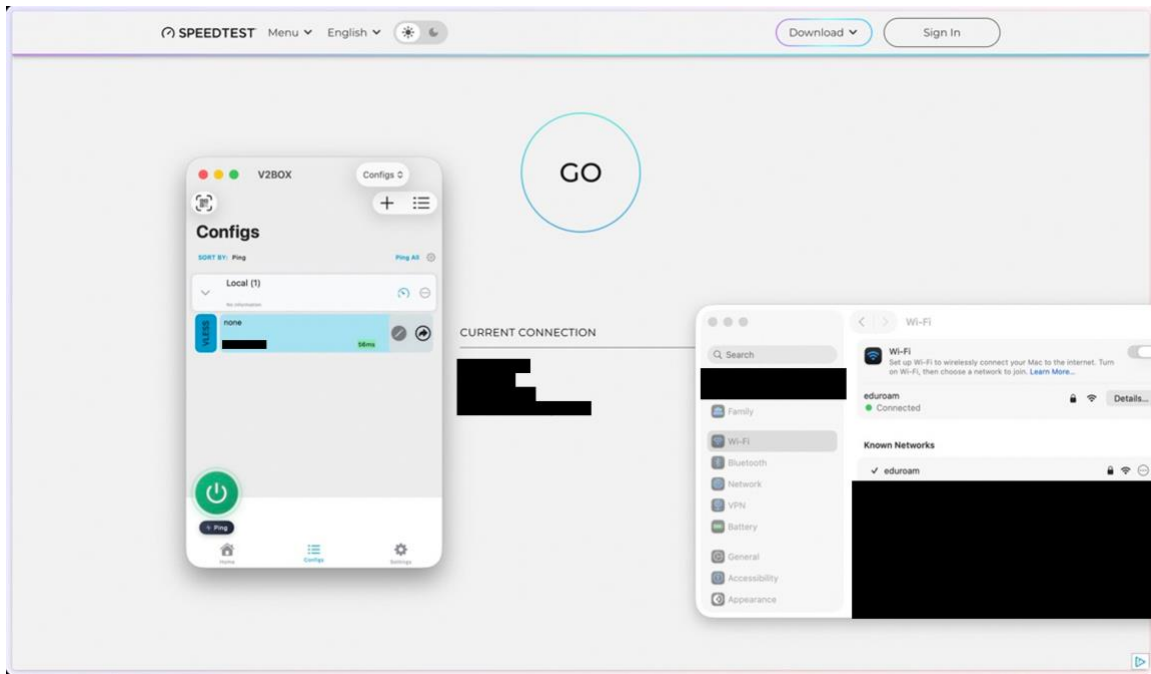


Fig. 5: Connection to VPS established via VLESS/Reality while still being on eduroam network. Ookla identifies this connection from the location of the VPS (redacted), **not** the college network.

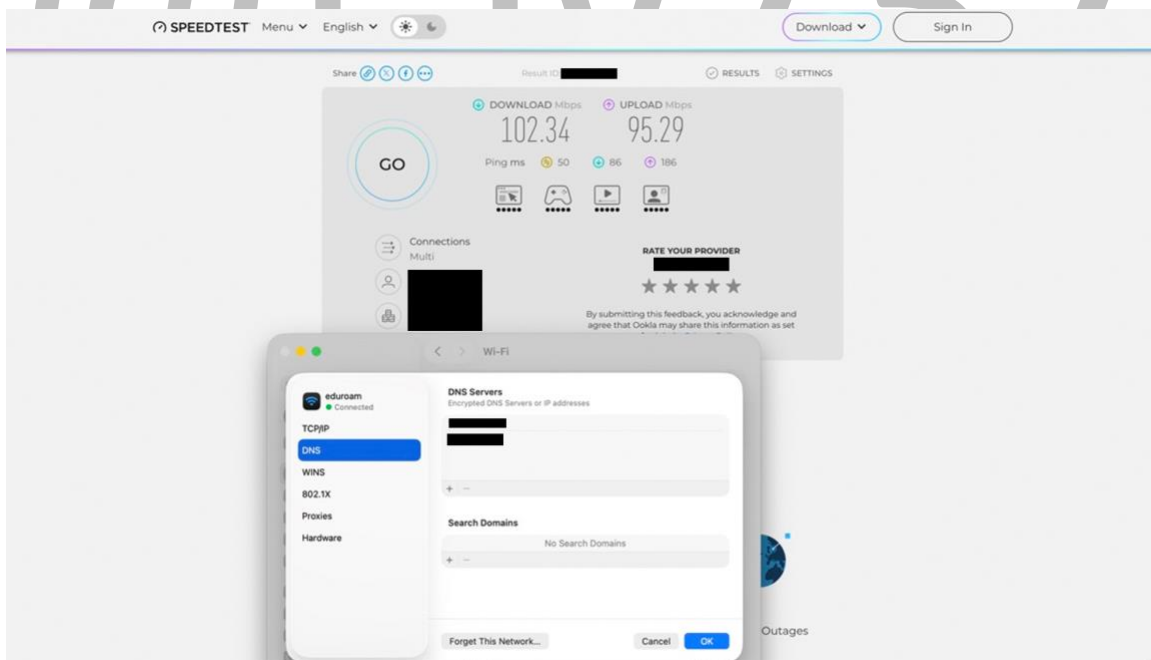


Fig. 6: Speed test results through the tunnel, evidence of continuous connection to eduroam, no settings were changed before or after, including the auto-configured DNS servers.

10 – Conclusion

This PoC demonstrated that a BYOD device on the eduroam network could establish an encrypted tunnel to an external VPS using V2Box and Xray-core with VLESS + Reality. The combination of SNI spoofing, tlshello fragmentation, TUN mode, Mux, and DoU with UseIP reduced the college network's ability to identify the final destinations and DNS lookups.

The issue is not specific to Xray, VLESS, Reality, or V2Box. The broader security concern is that users who can freely establish encrypted connections to arbitrary external systems may be able to move Internet traffic beyond the visibility of destination-based network controls.

The root cause is a lack of sufficiently restrictive outbound/egress controls, combined with the BYOD device being unmanaged (so endpoint controls did not apply).

10.1 – Mitigation

Effective mitigation will require a layered approach, for example:

Egress control (restrict outbound destinations)

Endpoint application control (on managed devices)

VPN/proxy detection (network-based)

DNS enforcement (block encrypted DNS bypass)

Monitoring and alerting (to detect tunnel behaviour)

The best next step is to replicate the finding in a controlled environment. This will help determine which existing tools or functions can detect block or allow this.

11 – References

Project X. "REALITY – A powerful transport protocol." – <https://github.com/XTLS/REALITY>

Project X. "[Xray-core](#)"

Project X. "[Project X Documentation.](#)"

Jisc. "[Janet security policy](#)"

Jisc. "[eduroam \(UK\) Technical Specifications](#)"

Fortinet. "[SSL/TLS Inspection.](#)"

Fortinet. "[Fortinet Document Library](#)"

Lightspeed Systems. "[Lightspeed Filter Documentation](#)"

@tay737

12 – Appendices

12.1 – Appendix A: Glossary

Term	Definition
BYOD	Bring Your Own Device – personal device, unmanaged.
VPS	Virtual Private Server
Xray-core	Open-source proxy/tunnelling software.
VLESS	Proxy protocol used by Xray
Reality	Transport method that mimics a real website's TLS fingerprint
V2Box	Client application for Xray-core
TUN	Virtual network interface that captures device-wide traffic
Mux	Multiplexing – combining multiple streams into one connection
SNI	Server Name Indication – the hostname in a TLS handshake
tlshello	Xray fragmentation mode that splits the TLS ClientHello
DoU	DNS over UDP – a method of DNS resolution
UseIP	Query strategy that resolves domains to IPs
DPI	Deep Packet Inspection – analysing packet contents
NAC	Network Access Control – assessing device compliance before network access
eduroam	The international roaming network used by universities.
JANET	The UK's national education and research network. (NREN)
Fortinet / FortiGate	Firewall/security appliance vendor.
Lightspeed	Content filtering system used in education
TLS	Transport Layer Security – encryption protocol for HTTPS
ClientHello	The first message in a TLS handshake.
CDN	Content Delivery Network

12.2 – Appendix B: Attack chain

Phase	Step	Action
01	Ingress	Client authenticates via student credentials onto eduroam network.
02	Hooking	V2Box creates a virtual TUN interface routing all local L3 IP traffic.
03	Handshake	Client initiates connection over port 443 (TCP) using uTLS Chrome fingerprinting.
04	Obfuscation	SNI Spoofing targets a trusted domain; tlshello fragmentation splits the ClientHello packet.
05	Tunnelling	VLESS + Reality session, multiplexing and combining active streams
06	Resolution	Internal DNS queries are routed through the tunnel (UselP), hiding target hostnames.
07	Egress	VPS handles traffic, relays onward requests to final destinations

12.3 – Appendix C: Security control mapping

Feature	Traditional CASB	Tunnel-based CASB
Control	Normal traffic	Tunnelled Traffic (this PoC)
DNS filtering	High visibility	Reduced: DoU/UseIP moves DNS inside tunnel
Domain filtering	High visibility	Reduced: SNI spoofing hides final domain
URL filtering	High visibility	Reduced: URL inside encrypted tunnel
IP filtering	Destination visible	Tunnel endpoint visible; destination hidden
TLS/SNI analysis	Destination metadata visible	SNI may be spoofed; ClientHello may be fragmented
DPI	Protocol visibility	Encrypted payload limits visibility; fragmentation/Mux reduce signatures
Egress filtering	Controls destinations	Can prevent tunnel if arbitrary VPS is blocked
Endpoint control	Controls applications	Not effective on unmanaged BYOD
VPN/proxy detection	Variable	Potentially useful; must detect multiple technologies
Lightspeed bypass detection	Effective on managed devices	Not applicable to BYOD device-level tunnel
Network segmentation	Limits potential scope of damage	Limits potential scope of damage

End of report

This proof-of-concept report was prepared for the IT team. It did not involve attacking or exploiting any network infrastructure; it was a circumvention of existing measures. The intention was to identify and help mitigate any flaws in the current configuration, not to cause any malicious harm, hence the appropriate disclosure of all findings, In hopes for the appropriate solutions to be implemented.

@tay737